

Lista de Exercícios para Avaliação

Unidade 1 — Segurança de redes locais e de longa distância · Subunidade 1.1 — Introdução a testes de invasão

Nome do(a) aluno(a): Pedro Henrique de Brito Canabarro	Data: 10/08/2026
Professor: José Carlos Neto	Valor: 3,0 pontos (Listas/Prática — Av1)

Instruções

Responda a todas as questões de forma individual, com justificativa quando solicitado. Cálculos devem ser demonstrados — a resposta final sem o desenvolvimento não pontua integralmente. Consultas ao material de aula são permitidas; consulta a colegas, não.

Parte 1 — Conceitos de rede

1. [Conceitual] Explique a função de cada uma das quatro camadas do modelo TCP/IP, citando um protocolo de exemplo para cada uma.

O modelo TCP/IP é dividido em quatro camadas:

Camada de aplicação: é responsável pela comunicação entre os programas utilizados pelo usuário e a rede. Nela estão os protocolos que fornecem serviços diretamente às aplicações. Um exemplo é o HTTP, utilizado para a comunicação na Web. Outros exemplos são DNS, SSH e FTP.

Camada de Transporte: realiza a comunicação entre os processos executados nos dispositivos da rede. Pode oferecer comunicação confiável ou não, dependendo do protocolo utilizado. Um exemplo é o TCP, que realiza a entrega confiável dos dados. Outro protocolo desta camada é o UDP.

Camada de Internet/Rede: é responsável pelo endereçamento lógico dos dispositivos e pelo encaminhamento dos pacotes entre diferentes redes. O principal exemplo é o protocolo IP.

Camada de Acesso à Rede: cuida da transmissão dos dados pelo meio físico ou sem fio, permitindo que os dispositivos efetivamente enviem e recebam os dados pela rede. Um exemplo é o Ethernet, utilizado em redes cabeadas. Outro exemplo é o Wi-Fi.

2. [Conceitual] Diferencie TCP e UDP, citando ao menos duas características de cada um e um exemplo de aplicação que utiliza cada protocolo.

O TCP é um protocolo orientado à conexão e confiável. Antes da transmissão dos dados, é estabelecida uma conexão entre os dispositivos. Além disso, o TCP verifica se os dados chegaram ao destino e mantém a ordem correta dos pacotes. Um exemplo de aplicação que utiliza TCP é o SSH.

Características do TCP:

- Orientado à conexão
- Garante a entrega dos dados

- Garante a ordem dos pacotes
- Utiliza mecanismos de confirmação e retransmissão

Já o UDP é um protocolo não orientado à conexão. Ele envia os dados sem estabelecer previamente uma conexão e não garante que todos os pacotes chegarão ao destino ou que chegarão na ordem correta. Em compensação, possui menor sobrecarga e tende a ser mais rápido. Um exemplo de uso é o DNS.

Características do UDP:

- Não orientado à conexão
 - Não garante a entrega
 - Não garante a ordem dos pacotes
 - Possui menor sobrecarga e maior velocidade
-

3. [Conceitual] O que é NAT e por que ele continua sendo necessário na maioria das redes atuais, mesmo com a existência do IPv6?

O NAT é uma técnica responsável por traduzir endereços IP privados utilizados dentro de uma rede para um endereço IP público utilizado na internet. Por exemplo, vários computadores de uma empresa podem possuir endereços privados como 192.168.0.x, enquanto todos compartilham um mesmo endereço IPv4 público para acessar a internet. O NAT continua sendo bastante utilizado principalmente devido ao esgotamento dos endereços IPv4. Como a implantação do IPv6 ainda ocorre de forma gradual, muitas redes continuam dependendo do IPv4 e, conseqüentemente, do NAT para permitir que vários dispositivos compartilhem um único endereço público.

Parte 2 — Endereçamento e cálculo de sub-redes

4. [Cálculo] Para o bloco 172.16.0.0/22, calcule: (a) a máscara de sub-rede em notação decimal; (b) a quantidade de hosts utilizáveis; (c) o endereço de broadcast.

a) Um endereço IPv4 possui 32 bits. O prefixo /22 significa que 22 bits pertencem à parte da rede:
11111111.11111111.11111100.00000000

Convertendo cada octeto para decimal temos a máscara 255.255.252.0

b) $32 - 22 = 10$ bits disponíveis para hosts. Quantidade total de endereços: $2^{10} = 1024$, tirando 2 endereços para rede e broadcast temos 1022 hosts utilizáveis.

c) A máscara é 255.255.252.0, o tamanho do bloco no terceiro octeto é $256 - 252 = 4$.

Portanto a rede iniciada em: 172.16.0.0 vai até 172.16.3.255

Assim: Endereço de rede: 172.16.0.0, primeiro host: 172.16.0.1, último host: 172.16.3.254, broadcast: 172.16.3.255

5. [Cálculo] Divida o bloco 200.10.5.0/24 em 8 sub-redes de tamanho igual. Indique a nova máscara (CIDR) e liste os 8 blocos resultantes.

Precisamos criar 8 sub-redes. Então precisamos de $2^n = 8 \Rightarrow n = 3$. A rede original possui prefixo /24, adicionando 3 bits temos 27.

Portanto a nova máscara será: CIDR /27 em decimal: 255.255.255.224. O tamanho de cada bloco é $256 - 224 = 32$, assim, cada sub-rede terá 32 endereços. As oito sub-redes são

Sub-rede 1: Bloco 200.10.5.0/27

Sub-rede 2: Bloco 200.10.5.32/27

Sub-rede 3: Bloco 200.10.5.64/27

Sub-rede 4: Bloco 200.10.5.96/27

Sub-rede 5: Bloco 200.10.5.128/27

Sub-rede 6: Bloco 200.10.5.160/27

Sub-rede 7: Bloco 200.10.5.192/27

Sub-rede 8: Bloco 200.10.5.224/27

6. [Cálculo] Os hosts 10.20.30.10/28 e 10.20.30.30/28 estão na mesma sub-rede? Demonstre o cálculo que justifica sua resposta.

Não estão, a máscara /28 corresponde a 255.255.255.240, calculando o tamanho dos blocos temos $256 - 240 = 16$. Portanto as sub-redes avançam de 16 em 16.

10.20.30.0 até 10.20.30.15, 10.20.30.16 até 10.20.30.31, 10.20.30.32 até 10.20.30.47 e por aí vai...

O endereço 10.20.30.10 pertence à rede 10.20.30.0/28 (1º intervalo). Já o endereço 10.20.30.30 pertence à rede 10.20.30.16/28 (2º intervalo), portanto os dois hosts não estão na mesma sub-rede.

Parte 3 — Serviços, ataques e testes de invasão

7. *[Aplicação]* Complete a tabela abaixo com o protocolo de transporte (TCP ou UDP) e o serviço correspondente a cada porta.

Porta	Protocolo (TCP/UDP)	Serviço
21	TCP	FTP - CONTROLE
25	TCP	SMTP - ENVIO DE E-MAIL
110	TCP	POP3 - RECEBIMENTO DE E-MAIL
143	TCP	IMAP - ACESSO/RECEBIMENTO DE E-MAIL
3306	TCP	MYSQL - BANCO DE DADOS

8. *[Conceitual]* Diferencie os três tipos de teste de invasão — black box, grey box e white box — e indique uma situação em que cada um seria o mais indicado.

Black Box: o profissional realiza o teste sem possuir informações prévias sobre o ambiente. Dessa maneira, a abordagem procura simular a situação de um atacante externo que precisa descobrir os sistemas, serviços e possíveis vulnerabilidades.

Exemplo: uma empresa deseja avaliar o que um atacante externo conseguiria descobrir e explorar tendo somente seu endereço ou domínio público.

Grey Box: o profissional recebe algumas informações ou um nível limitado de acesso ao ambiente. Dessa forma, representa uma situação intermediária entre black box e white box.

Exemplo: fornecer ao profissional uma conta de usuário comum para verificar quais vulnerabilidades poderiam ser exploradas por um funcionário ou por alguém que conseguiu comprometer uma credencial.

White Box: o profissional recebe informações completas sobre o sistema, podendo possuir acesso à arquitetura, configurações e outros recursos necessários para realizar uma análise aprofundada.

Exemplo: uma empresa deseja realizar uma auditoria completa de segurança de uma aplicação e fornece ao profissional todas as informações necessárias para analisar profundamente o ambiente.

9. *[Conceitual]* Segundo a Lei 12.737/2012, por que um teste de invasão realizado sem autorização formal é considerado crime, mesmo quando feito com boas intenções?

Segundo a abordagem apresentada no material, a Lei nº 12.737/2012 tipifica como crime a invasão de dispositivo informático mediante violação indevida de mecanismos de segurança.

Dessa maneira, realizar um teste de invasão em um sistema sem possuir autorização do responsável significa acessar ou tentar acessar um ambiente para o qual o profissional não recebeu permissão.

Mesmo que a pessoa alegue que pretendia apenas encontrar vulnerabilidades ou ajudar a organização, **a boa intenção declarada não substitui a autorização do responsável pelo sistema.**

Por esse motivo, antes de iniciar um teste de invasão, é necessário possuir autorização formal e definir claramente quais sistemas e recursos poderão fazer parte do teste.

10. [Dissertativa] Cite dois controles de rede vistos em aula (por exemplo: firewall, VLAN, MFA, segmentação) e explique como cada um reduz a superfície de ataque em uma rede corporativa.

Dois controles que podem ser utilizados são **Firewall** e **VLAN**.

1. Firewall

O firewall controla o tráfego de entrada e saída da rede utilizando regras previamente definidas. Ele pode permitir ou bloquear conexões de acordo com critérios como endereço IP, protocolo e porta.

Por exemplo, caso uma empresa não precise disponibilizar determinada porta para acesso externo, o firewall pode bloquear as conexões destinadas a ela.

Com isso, diminui-se a quantidade de serviços que podem ser acessados por possíveis atacantes, reduzindo a **superfície de ataque** da organização.

2. VLAN

Uma VLAN permite dividir logicamente uma rede em diferentes segmentos. Assim, dispositivos que estão fisicamente na mesma infraestrutura não precisam necessariamente pertencer à mesma rede lógica.

Caso um computador conectado à VLAN de visitantes seja comprometido, a segmentação pode impedir ou dificultar que o atacante acesse diretamente os computadores da administração.

Dessa maneira, as VLANs ajudam a **isolar os segmentos da rede e limitar o movimento lateral de um atacante**, reduzindo o impacto que o comprometimento de um único dispositivo pode causar.

O gabarito também considera MFA e segmentação como respostas válidas, desde que a justificativa explique adequadamente como reduzem a exposição da rede.

GABARITO — USO DO PROFESSOR

Referências de correção — aceitar respostas equivalentes, desde que corretamente justificadas.

1. Camadas do TCP/IP

Aplicação (HTTP, DNS, SSH, FTP) — troca de dados entre programas; Transporte (TCP, UDP) — entrega entre processos, com ou sem garantia; Internet/Rede (IP, ICMP) — endereçamento e roteamento entre redes; Acesso à rede (Ethernet, Wi-Fi) — transmissão física dos bits.

2. TCP x UDP

TCP: confiável, orientado a conexão, garante ordem e entrega (three-way handshake) — ex.: HTTP, SSH. UDP: sem conexão, mais rápido, não garante entrega/ordem — ex.: DNS, streaming, VoIP.

3. NAT

Traduz endereços privados internos em um único IP público, permitindo que vários dispositivos compartilhem um IPv4 — ainda essencial pelo esgotamento do IPv4 e pela adoção parcial/gradual do IPv6.

4. 172.16.0.0/22

(a) Máscara: 255.255.252.0. (b) Hosts utilizáveis: $2^{10} - 2 = 1022$. (c) Broadcast: 172.16.3.255.

5. 200.10.5.0/24 em 8 sub-redes

Nova máscara: /27. Blocos: 200.10.5.0/27, .32/27, .64/27, .96/27, .128/27, .160/27, .192/27, .224/27.

6. 10.20.30.10/28 e 10.20.30.30/28

Não estão na mesma sub-rede: cada bloco /28 tem 16 endereços; 10.20.30.10 pertence a 10.20.30.0/28 (0–15) e 10.20.30.30 pertence a 10.20.30.16/28 (16–31).

7. Tabela de portas

21 → TCP → FTP (controle) · 25 → TCP → SMTP (envio de e-mail) · 110 → TCP → POP3 · 143 → TCP → IMAP · 3306 → TCP → MySQL

8. Tipos de teste de invasão

Black box: nenhuma informação prévia — simula atacante externo. Grey box: informação parcial (ex.: conta comum) — simula ameaça interna limitada. White box: acesso completo — foca profundidade, não descoberta.

9. Lei 12.737/2012

A lei tipifica como crime a invasão de dispositivo informático mediante violação indevida de mecanismo de segurança — a intenção declarada não afasta o crime; só a autorização formal do responsável pelo sistema o faz.

10. Controles de rede (resposta aberta)

Aceitar qualquer combinação coerente — ex.: Firewall/ACL filtram tráfego por regra; VLAN isola segmentos e limita movimento lateral; MFA reduz o impacto de uma senha vazada; segmentação limita o alcance de um host comprometido.